12. Security and Governance in the Gym Membership Application

Aim:

To examine and configure suitable user permissions, record access, sensitive-field protection and administration practices for the Gym Membership application.

Theory:

Least-privilege access grants only the operations needed for a responsibility. Permission sets control component and field operations, while roles and sharing rules influence record access. Hiding a page element is not a substitute for restricting access to the underlying form, report or API. Governance adds ownership, controlled changes, periodic access review and activity monitoring.

Existing Configuration:

Area	Evidence in the Application Export
Front Desk profile	Access to selected member reports and the Command Center; spreadsheet View/Edit permission; field-level restrictions; API access disabled.
Manager profile	Member creation, Viewall and Export permissions; selected reports and Command Center access; API access disabled. Description states unassigned and no users invited.
Role hierarchy	A CEO role is defined. Additional staff-role assignments are not evidenced.
Sensitive data	Name, email, contact number, address and signature have personal-data markings. Marking is not a substitute for access restrictions.
Other profiles	Default Read, Write, Administrator, Developer and Customer profile definitions exist; their existence does not establish actual user assignments.

Recommended Access Policy:

Front Desk should handle enrollment, attendance, fee status and renewal dates without unnecessary access to medical notes, certificates, media or bulk exports. Managers should receive broader operational access only where needed. Trainer access should be limited to assigned members and relevant fitness details. These are target policies to validate, not confirmed assignments.

Procedure:

1. Open the application settings and review users, roles, permission sets and sharing configuration.

2. Inventory personal, health-related, financial and operational fields. Identify who needs each category.

3. Review Front Desk and Manager component permissions. Remove operations not needed for their responsibilities.

4. Review sensitive-field visibility and read/write permissions individually. The existing Front Desk profile still allows personal-data access and many fields to be visible; verify that this matches the intended policy.

5. Keep the operational spreadsheet fields editable as required, and confirm that protected fields cannot be changed through alternate views or direct record links.

6. Create or confirm required roles, assign authorized users and review record ownership, sharing and hierarchy behavior. Do not infer record isolation from a profile name.

7. Review manager-only export requirements and test both report export and underlying data access.

8. Review authentication and session settings. Inspect audit-trail availability and retention for the subscription; record which relevant operations are logged.

9. Keep a controlled backup/export, document changes and restrict development privileges. Test restoration using a suitable development copy.

10. Run the access tests using separate authorized accounts and repeat them after permission changes.

Governance Practices:

Maintain an access register containing user, role, permission set, owner and review date. Remove unused accounts, revoke obsolete connections, document configuration changes and review exports. Define retention and deletion rules for photos, certificates, signatures and health notes. Keep credentials outside source code and shared screenshots.

Access Verification Matrix:

Action	Expected Policy	Evidence Needed
Front Desk marks attendance	Allowed	Account-specific successful edit.
Front Desk changes protected fee input	Blocked	Denied edit through all relevant views.
Front Desk exports member records	Blocked	Export unavailable or denied.
Manager exports approved member data	Allowed if authorized	Successful export with intended field scope.
Trainer opens unrelated member record	Blocked under target policy	Denied direct-link and report access.
Unauthorized user opens Command Center	Blocked	Page and underlying components inaccessible.
Medical certificate access	Limited to authorized users	File access test, not only hidden field display.
Record modification or export	Tracked where supported	Corresponding audit event and retention review.

Configuration Findings:

Profiles and field restrictions are present, but user assignments, record-sharing behavior and audit settings are not demonstrated. The Manager profile is explicitly described as unassigned. A profile granting personal-data access must still be checked against the intended sensitive-field policy.

Result:

Existing Gym Membership permissions and personal-data markings were reviewed, and an access policy, administration procedure and verification matrix were prepared. The export supports that profiles and restrictions are configured; successful multi-user enforcement, sharing rules and audit coverage require account-specific evidence before implementation can be considered fully verified.